CASE STUDY

The Instructure Canvas Breach and ShinyHunters Extortion of 2026: A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people in this breach are students and teachers. In the first week of May 2026, during final examinations, learners at schools and universities across the United States and beyond [14] opened the Canvas learning platform and found it in maintenance, or found an extortion message where their login page should be [5] [8] [19] (**Confirmed** for the maintenance and the letter; **Reported** for the login pages). Rutgers suspended Canvas access and ran degraded until 13 May [13] (**Confirmed**), and some colleges canceled exams [22] (**Reported**).

The vendor, Instructure, detected unauthorized activity in Canvas on 29 April 2026 [1] (**Confirmed**). Its customer FAQ says the actor opened a Free-for-Teacher account, filed a support ticket carrying malicious code, and, when a customer service agent opened the ticket, used a cross-site scripting flaw to obtain an authorization token with elevated access inside Canvas [2] (**Confirmed**). Instructure said on 2 May that "at this stage" it believed the incident was contained [3] (**Confirmed**); on 7 May the same actor came back through a second cross-site scripting flaw and posted a ransom note on login pages [2] (**Confirmed**). On 11 May Instructure said it had reached an agreement with the actor: the data was returned, destruction was confirmed with shred logs, and no customer would be extorted [1] (**Confirmed**).

No CVE is published for the Canvas flaws [10] and CISA KEV has no Instructure or Canvas entry [9] (**Confirmed**); the Intelligence Hub shards agree [11] (**Demonstrated**).

Key facts at a glance

Field	Value
Vendor and product	Instructure; the Canvas learning platform, hosted as a service [1] [2] (**Confirmed**)
Scale of the platform	More than 30 million active users and more than 8,000 institutions, as the House committee cites Instructure [8] (**Confirmed** as the committee states it)
Entry point	A Free-for-Teacher (FFT) account and the Canvas support-ticket workflow [1] [2] (**Confirmed**)
Weakness	Cross-site scripting: a support ticket (first intrusion) and the discussion feature (7 May) [2] (**Confirmed**); stored-XSS class **Inferred** from content that another user rendered
Intrusion windows	Logs may show support-account access 25 to 30 April and briefly on 7 May 2026, per the vendor's log guidance [2]; detection 29 April [1] (**Confirmed**)
Data, per the vendor	Names, usernames, email addresses, student ID numbers, course names, enrollment information and messages; no evidence of passwords, dates of birth, government IDs or financial data [1] [3] (**Confirmed**); later deliveries cover API provisioning records, user reports and DAP messaging data [1] (**Confirmed**)
Data, per the actor	3.65 TB on 275 million people at nearly 9,000 institutions; later 280 million records from 8,809 institutions [17] [18] (**Reported**, unverified claims)
Extortion	Ransom note on login pages, 7 May, deadline 12 May [2] [19]; agreement 11 May [1] (**Confirmed** for the note and the agreement; **Reported** for the deadline)
Attribution	Claimed by ShinyHunters [16] (**Reported** for the claim); the vendor FAQ says both the 2025 Salesforce incident and the 2026 Canvas attacks "appear" to be ShinyHunters' work [2] (**Confirmed** that the vendor says so); ATT&CK tracks ShinyHunters as G1057 [26] (**Confirmed** for the ATT&CK object; **Inferred** binding to G1057)
CVE and KEV	No published CVE [10]; KEV catalog 2026.11.10 has no Instructure or Canvas row [9] (**Confirmed**)
Government	House Homeland Security Committee letter, 11 May 2026, asking for a briefing by 21 May [8]; FBI PSA of 15 May on a ShinyHunters attack on an unnamed learning management system [28] (**Confirmed**; **Inferred** that the PSA means Canvas)

Key findings

- **"Contained" lasted five days.** Instructure said on 2 May it believed the incident was contained and that patches were deployed [3] (**Confirmed**). On 7 May the same actor used a second, unpatched flaw of the same class, using the OAuth flow to generate a token and so sidestepping the earlier fix [2] (**Confirmed**). Fixing one instance of a bug class left its sibling open (**Inferred**).
- **The weakest tenant reached the strongest accounts.** A free, self-service account could put script in front of a support agent whose session carried elevated access within the Canvas application [2] (**Confirmed**), which reached paid institutional tenants (**Inferred** from the roughly 300 affected organizations [2]). Instructure's answer was to close Free-for-Teacher for good and suspend support agents' administrative and user-spoofing privileges [1] [2] (**Confirmed**).
- **Bulk export features were the likely collection path.** The actor claims it used DAP queries, provisioning reports and user APIs [18] (**Reported**), and the vendor's own data deliveries match those categories [1]

(**Confirmed** for the categories; **Inferred** that export features were the path).

- **The data story grew over time.** Early statements listed names, emails, IDs and messages [3]; the July deliveries added API provisioning records and user reports [1] (**Confirmed**). No count of people or institutions has been published [1] (**Confirmed** for the absence).

Top recommendations

1. Review Canvas logs for access from Canvas customer support representative accounts between 25 and 30 April and on 7 May 2026, especially rapid access to many courses or users [2] (**Confirmed** vendor guidance). It is the one customer-side indicator, and only institutions that export Canvas logs can check it (**Inferred**).
2. Enforce MFA on privileged accounts, review administrative access, and rotate API tokens and keys for integrations where applicable [3] (**Confirmed** vendor guidance). Keep an inventory of which tools hold Canvas keys and who re-authorizes them: customers reported that key reissue broke integrations and gradebook sync [6] (**Reported**), and an inventory shortens that outage (**Inferred**).
3. Ask every SaaS vendor how support staff reach tenant data: impersonation rights, token lifetimes, and whether low-trust tenants can submit content those staff render [2] (**Inferred** from the vendor's own hardening list).
4. Plan for an LMS outage during exams: grade export and provisioning workarounds like the ones Rutgers issued [13] (**Confirmed** for Rutgers; **Inferred** as general advice).

Scope and method

This brief covers the Canvas intrusions of April and May 2026, the extortion, the response through 29 September 2026 and the earlier September 2025 Salesforce incident as context. The technical record stays at advisory level: it names the flaw class and the abused features and gives no exploit detail. The leak site was not visited.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Instructure's incident hub, FAQ, status pages and community notice; the House committee letter; victim institutions' notices; CISA KEV; NVD; ATT&CK and library data. A vendor's account of its own incident is Confirmed as the vendor's statement
Reported	Journalism, the actor's claims, or a secondary account of a primary that could not be opened
Demonstrated	This study's own check of a dataset (the Intelligence Hub shards)
Inferred	This study's reasoning from cited facts, labelled where it appears

Part 1: what happened

Times are as the status pages give them, in Mountain Daylight Time (MDT).

Date (2026 unless stated)	Event	Sources	Grade
21 Sep 2025	Instructure discloses a social-engineering compromise of its Salesforce instance, exposing largely public business contact information and no product data; federal law enforcement notified	[7]	Confirmed
25 to 30 Apr	Window in which institution logs may show the actor using Canvas customer support representative accounts	[2]	Confirmed
29 Apr	Instructure detects unauthorized activity in Canvas, revokes the party's access, opens an investigation and engages outside forensic experts	[1]	Confirmed
30 Apr, 17:06	Status page reports limited disruption to tools relying on API keys after precautionary steps; reissued keys carry a 2026-04-30 timestamp	[4] [6]	Confirmed
1 May	Canvas Data 2, Beta and Test placed under maintenance	[4]	Confirmed
1 May, 16:30	"Confirmed Security Incident" posted by CISO Steve Proud: a criminal threat actor, outside forensics engaged	[3]	Confirmed
2 May	Incident believed contained; privileged credentials and tokens revoked, patches deployed, keys rotated, monitoring increased; data types listed	[3]	Confirmed
2 to 3 May	Application keys reissued; users must re-authorize integrated tools; customers report broken integrations and gradebook sync	[6]	Confirmed (reissue); Reported (customer breakage)
3 May	ShinyHunters lists Instructure on its leak site: 3.65 TB, 275 million people, nearly 9,000 institutions, plus a claimed Salesforce compromise	[16] [17]	Reported
3 May, 16:35	Canvas Data 2 available for all customers	[4]	Confirmed
4 May	Canvas Beta restored; University of Colorado calls it a nationwide event and says it has not been notified of direct impact	[4] [12]	Confirmed
5 May	Actor claims 280 million records from 8,809 institutions, publishes an institution list, and says it used DAP queries, provisioning reports and user APIs	[18]	Reported
6 May	Tilburg University says Instructure confirmed its student and staff data was affected	[14]	Confirmed
6 May, 13:17	Canvas Data 2, Beta and Test all available	[4]	Confirmed
6 May	Final status update: no ongoing unauthorized activity; enforce MFA on privileged accounts, review admin access, rotate tokens	[3]	Confirmed
7 May	The same actor re-enters through a second XSS flaw in the discussion feature, using the OAuth flow to generate a token; logs may show brief support-account access	[2]	Confirmed
7 May	Ransom note posted through custom-theme CSS, visible to roughly 300 organizations; some authentication provider configurations disrupted; disabled about 10 minutes after it began; Instructure says it does not believe any customer data was compromised on 7 May	[1] [2]	Confirmed

Date (2026 unless stated)	Event	Sources	Grade
7 May	Press counts about 330 institutions' login pages defaced for about 30 minutes, the message also in the Canvas app, deadline 12 May; TechCrunch sees it on three schools' pages	[19] [23]	Reported
7 May, 14:41 to 21:17	Status incident opened; Canvas, Beta and Test in maintenance (notice 17:37); Canvas available for most users at 21:17	[5]	Confirmed
8 May	CEO Steve Daly apologizes for inconsistent communication, lists the data fields, names a support-ticket vulnerability in the Free for Teacher environment and disables FFT	[1]	Confirmed
8 May	Rutgers reinstates basic Canvas tools that night after consulting experts and a consortium of affected universities	[13]	Confirmed
8 May	FBI says on X it is aware of the disruption and advises victims not to pay or respond	[24]	Reported (post not opened)
9 May	Canvas fully back online; CrowdStrike engaged; an e-discovery vendor onboarded	[1]	Confirmed
11 May	Agreement with the actor: data returned, shred logs, no customer to be extorted	[1]	Confirmed
11 May	House Homeland Security Chairman Andrew R. Garbarino writes to the CEO, asking for a briefing by 21 May and confirmation by 14 May	[8]	Confirmed
11 May, 16:21	All Canvas environments available; status incident resolved	[5]	Confirmed
12 May	Leak-site entry removed	[21] [24]	Reported
13 May	Parchment scanned for the actor's IOCs, no lateral movement from Canvas; CrowdStrike Falcon EDR across the network; Rutgers restores GradeSync and provisioning	[1] [13]	Confirmed
15 May	FBI PSA I-051526-PSA: ShinyHunters claimed a cyber-attack on an online learning management system that interrupted service to educational institutions and students across the country; the platform is fully operational; no platform is named	[28]	Confirmed (Inferred that it means Canvas)
18 May	CISO technical webinars for customers	[2]	Confirmed
21 May	Preliminary findings on exfiltrated data fields delivered to Canvas administrators	[2]	Confirmed
26 May	CEO letter says the initial response made things worse; Security and Resilience Advisory Board led by Chief Academic Officer Melissa Loble	[1]	Confirmed
28 to 29 May	First temporary FFT download window; FFT permanently discontinued (stated by 8 Jun)	[1]	Confirmed
8 Jul	Data delivery to institutions through ShareFile announced; forensic review by CrowdStrike and Charles River Associates	[1]	Confirmed

Date (2026 unless stated)	Event	Sources	Grade
14 Jul	Delivery paused over a threat disclosed against ShareFile's on-premise servers, which did not involve Canvas	[1]	Confirmed
21 to 26 Jul	Delivery of API provisioning records and user reports begins 26 Jul; Kroll handles opt-in user notification; DAP messaging data stays under review	[1]	Confirmed
29 Sep	Forensic review complete; final delivery phase begins; further updates go directly to institutions	[1]	Confirmed

Part 2: the intrusion record

First intrusion. The vendor FAQ describes the chain: the actor created a Free-for-Teacher account and submitted a support ticket containing malicious code. When a customer service agent opened the ticket, a cross-site scripting flaw let the actor obtain an authorization token and gain elevated access within the Canvas application [2] (**Confirmed**). The log indicator follows from that: activity from Canvas customer support representative accounts between 25 and 30 April, with rapid access to many courses or user accounts [2] (**Confirmed**). BleepingComputer's sources describe multiple XSS flaws in user-generated content features that yielded authenticated admin sessions [20] (**Reported**).

Collection. The actor says it used Canvas's own export features: DAP queries, provisioning reports and user APIs [18] (**Reported**). Instructure's deliveries to institutions describe API provisioning records, user reports and DAP messaging data as the exfiltrated data [1] (**Confirmed**). No source states the exfiltration channel (**Inferred** from the absence).

Containment and the return. By 2 May Instructure had revoked privileged credentials and access tokens, deployed patches, rotated certain keys and increased monitoring [3] (**Confirmed**). On 7 May the same actor used a second, unpatched XSS in the discussion feature, sidestepping the earlier fix by using the OAuth flow to generate a token [2] (**Confirmed**). It posted the ransom note through CSS in a Canvas custom theme and disrupted some authentication provider configurations; monitoring added after the first attack detected and disabled the change about 10 minutes after it began, and Instructure says no additional data was taken [1] [2] (**Confirmed** as the vendor's statement).

Hardening. The vendor lists: administrative access restricted to trusted locations with rate limiting; sensitive admin paths locked down; internal tools moved to internal APIs; third-party integrations geo or network restricted; all employee sessions and internal tokens cycled; token expiration enforced and lifetime tokens removed; support agents' admin and user-spoofing privileges suspended [2] (**Confirmed**). Free-for-Teacher was disabled on 8 May and later discontinued [1] (**Confirmed**). There is no customer-installed fix: the remediation is the vendor's, on the service (**Inferred**).

Part 3: who and why

Attribution, stated as each source states it:

- **Instructure's status pages** name no group: "a criminal threat actor" [3], and on the incident hub a cybercriminal organization known for large-scale attacks across technology and education [1] (**Confirmed**).
- **Instructure's FAQ** says the September 2025 Salesforce incident and the 2026 Canvas attacks appear to have been carried out by ShinyHunters [2] (**Confirmed** that the vendor says so).
- **ShinyHunters** claimed the breach on its leak site [16] (**Reported**). For 7 May, Instructure says it was the same threat actor [1] (**Confirmed**); a ShinyHunters member told TechCrunch it was a separate breach [24] (**Reported**).
- **The FBI**, in its PSA of 15 May, says ShinyHunters claimed the cyber-attack that interrupted an online learning management system used by educational institutions across the country, and warns that victims may receive extortion email signed as ShinyHunters [28] (**Confirmed** that the FBI says so). The PSA names no platform; reading it as Canvas rests on the dates and the House letter (**Inferred**).
- **The House committee** says the group known as ShinyHunters breached Instructure twice within one week, footnoting press reports [8] (**Confirmed** that the committee says so; the attribution itself rests on press).
- **ATT&CK** tracks ShinyHunters as G1057 (aliases UNC6240, Bling Libra), a criminal collective active since at least 2019 that it associates with The Com alongside Scattered Spider (G1015) and LAPSUS$ (G1004) [26] [27] (**Confirmed** for the ATT&CK object). ATT&CK does not list this incident; binding it to G1057 rests on the actor's claim and the vendor's "appear" wording (**Inferred**).

Motive. The record shows money: a ransom note with a deadline [19], an agreement [1], and a vendor FAQ that answers a question phrased "Why did Instructure decide to pay the ransom" without disputing the premise, calling it a difficult decision made to prevent distribution of the data [2] (**Confirmed**). No amount is published [1] [2] (**Confirmed** for the absence).

Part 4: impact and response

Students, teachers and institutions. The committee letter lists institutions in California, Florida, Georgia, Oklahoma, Oregon, Nevada, North Carolina, Tennessee, Utah, Virginia and Wisconsin among those affected during finals and calls the event a matter of national concern [8] (**Confirmed** as the letter states it). Rutgers suspended access after 7 May, reinstated basic tools on 8 May and restored GradeSync and provisioning by 13 May with workarounds for final grades [13] (**Confirmed**). Tilburg University is working with SURFcert and Universities of the Netherlands and warned users about phishing [14] (**Confirmed**). A screenshot shows the University of Texas at San Antonio login page carrying the message [21] (**Reported**).

The vendor. Beyond containment, Instructure engaged CrowdStrike, rolled out Falcon EDR, swept Parchment for the actor's IOCs, delivered per-institution data packets through ShareFile to designated security contacts, and had Kroll coordinate end-user notification [1] (**Confirmed**). Its 8 May and 26 May letters admit communication failures [1] (**Confirmed**).

The agreement. Instructure says the data was returned, it received digital confirmation of destruction (shred logs), and the agreement covers all impacted customers [1] (**Confirmed**). The leak-site entry was then removed, which BleepingComputer notes usually follows a payment without confirming one [21] (**Reported**). The FBI advised victims not to pay [24] (**Reported**). At Change Healthcare in 2024, payment did not end the extortion (Change Healthcare 2024); TechCrunch cites the PowerSchool precedent [24] (**Inferred** lineage;

Reported for PowerSchool). A shred log is the actor's attestation, not proof (**Inferred**).

Government and regulators. The House Homeland Security Committee asked for a briefing covering both intrusions, the data accessed, containment, notification and coordination with federal law enforcement and CISA [8] (**Confirmed**). The FBI's PSA of 15 May told students and staff to wait for their institutions' guidance on scope and affected data and warned that stolen education data could feed spearphishing that impersonates faculty, IT support or financial aid offices [28] (**Confirmed**); press reports say lawmakers then sought a closed-door briefing [25] (**Reported**). No state attorney general, FTC or Department of Education action appears in the sources opened (not checked beyond them).

CVE and KEV. No CVE is published for the Canvas flaws. An NVD keyword search for Instructure Canvas returns only CVE-2021-36539 (published 2023-01-26), and the KEV catalog has no entry [9] [10] (**Confirmed**). The Intelligence Hub KEV and history shards have no Instructure or Canvas rows [11] (**Demonstrated**).

Part 5: the defender and vulnerability-management view

- **A CVE queue saw nothing.** Two exploited flaws in a platform used by more than 8,000 institutions [8] have no published CVE [10] and no KEV row [9] (**Confirmed**); the Intelligence Hub shards agree [11] (**Demonstrated**). A vulnerability program that only tracks CVEs would have no ticket; the work sits in SaaS third-party risk, log review and integration hygiene (**Inferred**).
- **Treat XSS as a privilege problem.** The flaw class is ordinary; the impact came from whose browser rendered it [2] (**Confirmed** for the chain; **Inferred** for the lesson). Content from low-trust tenants should never render with staff privileges (**Inferred**).
- **Exam-week continuity.** The availability harm outlasted the 10-minute defacement: Canvas went into maintenance on the evening of 7 May (notice 17:37 MDT), was available for most users by 21:17 MDT, was fully back online on 9 May, and Beta and Test returned on 11 May [1] [5] (**Confirmed**); institutions such as Rutgers kept access suspended into 8 May [13] (**Confirmed**).

What is overstated and what is understated

- *Overstated:* the actor's counts (275 million people, 280 million records, 3.65 TB, 8,809 or nearly 9,000 or almost 15,000 institutions, several billion messages) disagree with one another, and BleepingComputer could not confirm them [16] [17] [18] (**Reported**). The leak-site removal is evidence consistent with a payment, not proof: BleepingComputer says removal usually follows a ransom payment [21] and TechCrunch reads it as a sign one may have been paid [24] (**Reported**). Sources disagree on the 7 May vector: the FAQ describes a second, unpatched XSS in the discussion feature but answers the login-page question with the support-ticket chain [2], and BleepingComputer reports the same vulnerability as the first intrusion [21] (**Reported**). This study follows the FAQ's discussion-feature account.
- *Understated:* the early vendor statements named neither the vector nor the actor, and "contained" on 2 May preceded a second intrusion through a sibling flaw [2] [3] (**Confirmed**). The early data list was narrower than the July deliveries [1] [3] (**Confirmed**). The vendor's "about 10 minutes" measures the second attack, not the disruption: Canvas maintenance ran into the night of 7 May, full service returned 9 May, and Rutgers ran degraded until 13 May [2] [5] [13] (**Confirmed** for the dates; **Inferred** for the contrast). And the FAQ's ransom answer concedes a payment the 11 May statement calls only an agreement [1] [2] (**Inferred**).

MITRE mappings

This Part binds the record to ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND, with names and tactics from the library's `data/attack/` and `data/weaknesses/` files [27]. No industrial system is involved, so no ATT&CK for ICS technique applies.

Groups, software and campaigns

Object	Name	Binding	Sources
G1057	ShinyHunters	Claimed actor; the vendor FAQ says the attacks appear to be its work; ATT&CK does not list this incident (**Inferred** binding)	[2] [16] [26]
C0059	Salesforce Data Exfiltration	The September 2025 social-engineering compromise of Instructure's Salesforce instance fits this campaign's pattern; ATT&CK does not list Instructure (**Inferred** fit)	[7] [27]
G1015, G1004	Scattered Spider, LAPSUS$	Context only: ATT&CK names them as fellow Com members in the G1057 entry; not bound to this incident	[26]

No software object is bound: no source names malware or a tool [1] [2] (**Inferred** from the absence).

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1585	Establish Accounts	Resource Development	Free-for-Teacher account created to file the support ticket (April 2026)	[2]
T1190	Exploit Public-Facing Application	Initial Access	XSS (stored class inferred) in a support ticket (April) and in the discussion feature (7 May)	[1] [2]
T1528	Steal Application Access Token	Credential Access	Authorization token taken from the agent's session; OAuth-flow token on 7 May	[2]
T1550.001	Application Access Token	Lateral Movement	Token used for elevated access within Canvas	[2]
T1078.004	Cloud Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Access from support representative accounts, 25 to 30 Apr and 7 May	[2]
T1213	Data from Information Repositories	Collection	DAP queries, provisioning reports and user APIs claimed (5 May); matching categories delivered (July)	[1] [18]
T1491.002	External Defacement	Impact	Ransom note on login pages through custom-theme CSS, 7 May	[1] [2] [19]
T1657	Financial Theft	Impact	Extortion: ransom note with a 12 May deadline; agreement 11 May	[1] [2] [19]
T1684	Social Engineering	Stealth	September 2025 Salesforce compromise, a separate earlier incident	[7]

Fit notes (**Inferred**): T1585 is a partial fit, because the account was created on the victim's own free tier. T1190 is a partial fit, because the flaw sits in the public-facing service but ran in an agent's browser. T1078.004 is a partial fit: the support accounts are SaaS application accounts, and the vendor describes their

use, not how they were held. T1213 rests on the actor's method claim and the vendor's data categories. T1684 covers only the vendor's phrase "social engineering"; the vishing sub-technique in C0059 is not bound, because Instructure does not name a channel. Left out: any exfiltration technique (no channel stated), T1119 Automated Collection (rapid access is described, automation is not), T1556 Modify Authentication Process (the disrupted provider configurations are not described as credential access), and T1059.007 JavaScript (stated only by BleepingComputer's unnamed sources [21], **Reported**; the vendor says "malicious code"; left out because the code ran in a victim's browser through the XSS, which CAPEC-592/CAPEC-63 already cover).

CWE and CAPEC

No CVE or NVD record exists, so no CWE is listed by an authority [10]. The vendor's description of cross-site scripting is the class of CWE-79, Improper Neutralization of Input During Web Page Generation [2] [27] (**Inferred**).

CAPEC	Name	Via	Where it meets the record
CAPEC-592	Stored XSS	CWE-79	Script stored in a support ticket and in a discussion, rendered by another user [2] (**Inferred**: the vendor does not say stored)
CAPEC-63	Cross-Site Scripting (XSS)	CWE-79	Parent pattern of CAPEC-592 [2]
CAPEC-21	Exploitation of Trusted Identifiers	T1528	Authorization token taken and reused [2]
CAPEC-593	Session Hijacking	T1550.001	Agent-level session and token used for elevated access [2]

D3FEND countermeasures

The library maps these D3FEND techniques to T1528, T1550.001 or T1078.004, and the vendor's record shows each in use [27]: Credential Revocation (privileged credentials and tokens revoked, 2 May [3]); Credential Rotation and Reissue Credential (keys rotated and reissued [3] [6]); Authentication Cache Invalidation (all employee sessions and internal tokens cycled [2]); User Account Permissions (support agents' admin and user-spoofing privileges suspended [2]); and Multi-factor Authentication (customer guidance, 6 May [3]). Token Binding is mapped too but not in the record (**Inferred** for each fit).

Navigator layer

The study's Navigator layer is `navigator/library-layers/instructure-canvas-breach-2026.json` (open in Navigator), listed on the Navigator layers page. Scores: 100 where a primary states the behavior and the fit is direct, 60 where the fit is partly inferred; each comment names its source numbers.

Cross-cutting themes

- **Concentration at an intermediary.** As at Change Healthcare and in the Cl0p file-transfer breaches, one platform in the middle of thousands of organizations set the blast radius, and the institutions' own controls did not decide the outcome (**Inferred**).
- **Data theft without encryption.** The extortion leaned on stolen data and public embarrassment, not encrypted systems [1] [19] (**Inferred**).

- **Repeat targeting of education vendors.** Infinite Campus, McGraw Hill and PowerSchool came before [15] (**Reported**).

Sources

All sources were opened on 11 November 2026, except [28], opened on 13 November 2026.

#	Source	URL	Opened	Grade
1	Instructure, Security Incident Update and FAQs hub (updates 8 May to 29 Sep 2026)	instructure.com/incident_update	2026-11-11	Confirmed
2	Instructure, incident FAQ for customers	instructure.com/incident-update/customers	2026-11-11	Confirmed
3	Instructure status page, Confirmed Security Incident (1 to 6 May 2026)	status.instructure.com/incidents/9wm4knj2r64z	2026-11-11	Confirmed
4	Instructure status page, Canvas Data 2, Beta and Test (30 Apr to 6 May 2026)	status.instructure.com/incidents/ns0sjlmkvc6g	2026-11-11	Confirmed
5	Instructure status page, Canvas is Available for Most Users (7 to 11 May 2026)	status.instructure.com/incidents/m88d7ymwpzpy	2026-11-11	Confirmed
6	Instructure Community, Application Key Timestamp Notice, 3 May 2026	community.instructure.com/en/discussion/665983/...	2026-11-11	Confirmed
7	Instructure blog, Security incident update (Salesforce), 21 Sep 2025	instructure.com/resources/blog/security-incident-update	2026-11-11	Confirmed
8	US House Committee on Homeland Security, letter to the Instructure CEO, 11 May 2026 (PDF)	homeland.house.gov/wp-content/uploads/2026/05/...	2026-11-11	Confirmed
9	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
10	NVD CVE API, keyword search "Instructure Canvas"	services.nvd.nist.gov/rest/json/cves/2.0?keywordSearch=...	2026-11-11	Confirmed
11	Team Star Wolf Intelligence Hub, feed.json and the v7 KEV and history shards	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Demonstrated
12	University of Colorado OIT, potential data breach involving Canvas, 4 May 2026	oit.colorado.edu/news/potential-data-breach-involving-canvas	2026-11-11	Confirmed
13	Rutgers IT alert, nationwide security breach involving Canvas, 4 to 13 May 2026	it.rutgers.edu/alerts/2026/05/04/...	2026-11-11	Confirmed
14	Tilburg University, possible data breach Canvas, 6 May 2026	tilburguniversity.edu/current/news/...	2026-11-11	Confirmed
15	BleepingComputer, Instructure discloses cyber incident, 1 May 2026	bleepingcomputer.com/news/security/edu-tech-firm-...	2026-11-11	Reported
16	BleepingComputer, Instructure confirms data breach, ShinyHunters claims attack, 3 May 2026	bleepingcomputer.com/news/security/instructure-confirms-data-breach-...	2026-11-11	Reported

#	Source	URL	Opened	Grade
17	SecurityWeek, EdTech firm Instructure discloses data breach, 4 May 2026	securityweek.com/edtech-firm-instructure-discloses-data-breach/	2026-11-11	Reported
18	BleepingComputer, hacker claims data theft from 8,800 schools and universities, 5 May 2026	bleepingcomputer.com/news/security/instructure-hacker-claims-...	2026-11-11	Reported
19	BleepingComputer, Canvas login portals hacked in mass extortion campaign, 7 May 2026	bleepingcomputer.com/news/security/canvas-login-portals-hacked-...	2026-11-11	Reported
20	BleepingComputer, Instructure confirms hackers used Canvas flaw to deface portals, 11 May 2026	bleepingcomputer.com/news/security/instructure-confirms-hackers-used-...	2026-11-11	Reported
21	BleepingComputer, Instructure reaches agreement with ShinyHunters, 12 May 2026	bleepingcomputer.com/news/security/instructure-reaches-agreement-...	2026-11-11	Reported
22	BleepingComputer, US government seeks Instructure testimony, 12 May 2026	bleepingcomputer.com/news/security/us-govt-seeks-instructure-...	2026-11-11	Reported
23	TechCrunch, hackers deface school login pages, 7 May 2026	techcrunch.com/2026/05/07/...	2026-11-11	Reported
24	TechCrunch, Instructure strikes deal with hackers who breached it twice, 12 May 2026	techcrunch.com/2026/05/12/...	2026-11-11	Reported
25	TechCrunch, US lawmakers demand answers from Instructure, 13 May 2026, updated 14 May	techcrunch.com/2026/05/13/...	2026-11-11	Reported
26	MITRE ATT&CK, Group G1057 ShinyHunters	attack.mitre.org/groups/G1057/	2026-11-11	Confirmed
27	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl`, `mitigation_to_technique.jsonl`, `data/weaknesses/cwe.jsonl`, `capec.jsonl` and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data	2026-11-11	Confirmed
28	FBI IC3, Public Service Announcement I-051526-PSA, ShinyHunters: Cyber Criminal Group Attacks Learning Management System, 15 May 2026	ic3.gov/PSA/2026/PSA260515	2026-11-13	Confirmed

Not opened, so not cited as sources: the FBI Cyber Division post on X (known only as TechCrunch quotes it), the NYT, CNN and The Verge articles the committee letter cites, the CrowdStrike interim fact sheet and the technical webinar recording behind the Instructure Community login, and the leak site, which this study does not visit.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- The Year 2026 in Intrusions, The DentaQuest Health-Data Breach of May 2026, Cloud Security Incidents (the 2025 Salesforce cases), The Ransomware Ecosystem
- Change Healthcare 2024, The Cl0p File-Transfer Breaches
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- SaaS Security Reference, Web Application Security Reference, API Security Reference, Identity Security Reference, Data Security Reference, Incident Response Reference, Threat Intelligence Reference, Supply Chain Security Reference
- Vulnerability Management Reference, Vulnerability Prioritization Reference
- Groups and campaigns: G1057 ShinyHunters, G1015 Scattered Spider, G1004 LAPSUS$, C0059 Salesforce Data Exfiltration
- Techniques: T1585 Establish Accounts, T1190 Exploit Public-Facing Application, T1528 Steal Application Access Token, T1550.001 Application Access Token, T1078.004 Cloud Accounts, T1213 Data from Information Repositories, T1491.002 External Defacement, T1657 Financial Theft, T1684 Social Engineering
- CAPEC: CAPEC-592 Stored XSS, CAPEC-63 Cross-Site Scripting (XSS), CAPEC-21 Exploitation of Trusted Identifiers, CAPEC-593 Session Hijacking
- Navigator layers, including this study's layer, instructure-canvas-breach-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies